SYSTEM CLASSIFICATION PROCESS

SOP-005 | Issued under POL-005 System Classification Policy

Document ID: SOP-005
Version: 1.0 — DRAFT
Parent Policy: POL-005 — System Classification Policy
Classification: Internal Use
Process Owner: Information Security
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	System Classification Process
Document ID	SOP-005
Version	1.0 — DRAFT
Status	Draft for Review
Parent Policy	POL-005 — System Classification Policy
Related Policy	POL-001 — Data Classification Policy
Related WI	WI-005 — System Classification Questionnaire
Process Owner	Information Security
Approved By	[CISO / CIO]
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Standard Operating Procedure defines the end-to-end process by which information systems at [Company Name] are classified by criticality, approved, registered, and periodically reviewed in accordance with the System Classification Policy (POL-005).

It translates POL-005 into a repeatable, auditable workflow — specifically operationalising the dual-input assessment model (data-derived criticality and functional criticality) and the reconciliation rule that produces a final system classification. Step-by-step task execution is supported by the System Classification Questionnaire (WI-005).

> **IMPORTANT:** No system may be deployed into a production environment without a completed, approved, and registered criticality classification. This is a hard gate.

2. Scope

This SOP applies to:

- All information systems being newly procured, developed, or onboarded into the [Company Name] environment
- All existing systems undergoing material changes to their function, data holdings, integrations, or regulatory scope
- All systems subject to annual classification review
- All deployment models: on-premises, cloud (IaaS, PaaS, SaaS), hybrid, and third-party managed

This SOP does not cover data asset classification (SOP-001), though data classification outputs are a direct input to this process. System Owners must ensure that the relevant data assets held by their system are classified under SOP-001 before or in parallel with completing this process.

3. Roles and Responsibilities

Role	Responsibility in this Process
Project / Procurement Lead	Initiates the classification process at the point a new system acquisition or development is approved. Ensures the System Owner is identified before classification begins.
System Owner	The primary participant in the classification process. Completes WI-005

Role	Responsibility in this Process
	(with IT input on Section B). Confirms the final classification and signs off the Asset Register entry. Accountable for annual review.
IT / Infrastructure	Co-completes Section B of WI-005 (functional criticality) with the System Owner. Responsible for implementing technical controls per the assigned tier. Advises on system dependencies and integration footprint.
Information Security	Reviews and validates all classifications. Sole approver for Tier 2 and Tier 3 classifications. Co-approver with CISO for Tier 1 classifications. Maintains this SOP and WI-005. Coordinates annual review cycle.
CISO	Co-approver (with Information Security) for all Tier 1 — Extremely Critical classifications. Final escalation point for classification disputes.
Compliance / QA	Reviews GxP and regulatory flag assignments. Confirms CSV/CSA requirements under POL-006 and SOX ITGC scope determination.
Business Continuity	Confirms that RPO and RTO targets for Tier 1 and Tier 2 systems are achievable given the proposed architecture and DR strategy.
CIO	Approves policy exceptions. Receives summary classification report as part of ISSG governance.

4. Trigger Events

The system classification process must be initiated when any of the following events occur:

Trigger	Description	Initiated By
New system procurement	A decision to procure a new system (including SaaS/cloud) has been approved. Classification must be completed before contract signature for systems anticipated to be Tier 1 or Tier 2, and before go-live for all systems.	Project / Procurement Lead
New system development	Internal development of a new application or platform is initiated. Classification must be completed at the design phase before development of production-bound components begins.	Project Lead / System Owner
Material system change	An existing system undergoes a change that materially alters its function, data holdings, integrations, or regulatory scope. Examples: GxP data is introduced; the system becomes a dependency of a Tier 1 system; a major new module is deployed.	System Owner
Regulatory scope change	A system is newly brought within GxP,	Compliance / QA /

Trigger	Description	Initiated By
	SOX, HIPAA, or other regulated scope. Reclassification is mandatory.	System Owner
Annual review	All classified systems are reviewed annually. The review date is set at initial classification and recorded in the Asset Register.	Information Security
Post-incident review	Following a significant incident involving a system, its classification must be reviewed to ensure controls remain appropriate.	Information Security / CISO

5. Pre-Conditions

Before the system classification process begins, the following must be in place:

Pre-Condition	Required For	Action if Not Met
System Owner identified and confirmed	All systems	Project Lead escalates to relevant business unit head to nominate a System Owner before classification proceeds.
Data classification completed for primary data types	All systems	System Owner initiates SOP-001 for the relevant data assets. System classification proceeds in parallel but is not finalised until data classification outputs are available.
High-level system description available	All systems	System Owner prepares a one-page system description covering: purpose, primary users, data held, integrations, and deployment model.
Vendor information available (for SaaS/cloud)	Third-party hosted systems	System Owner obtains vendor BCR/DR documentation, SLA commitments, and security certifications before completing WI-005 Section B.

6. Classification Process — Step by Step

The following steps constitute the full system classification workflow. For task-level execution detail, refer to WI-005 (System Classification Questionnaire).

Step 01	**Initiation and System Owner Confirmation** The trigger event is identified (see Section 4). The Project or Procurement Lead confirms that a System Owner has been named and notifies Information Security that a classification is required. Information Security opens a classification record and provides the System Owner with WI-005.	Responsible **Project Lead / InfoSec**
Step 02	**Data Classification Input (Section A of WI-005)** The System Owner completes Section A of WI-005, which captures the data-derived criticality assessment. For each primary data type held or processed by the system, the System Owner references the existing data classification (from SOP-001 / POL-001) and assesses: what is the operational impact if this data becomes unavailable or corrupted? The highest data criticality across all data types in the system is carried forward as Input A.	Responsible **System Owner**

IMPORTANT: Input A must be based on completed data classifications from SOP-001. Do not estimate data classification within this process. If data is unclassified, pause at this step and initiate SOP-001 before proceeding.

Step 03

Functional Criticality Assessment (Section B of WI-005)

The System Owner and IT jointly complete Section B of WI-005, which captures the functional criticality assessment. This assessment is independent of the data held and asks: what is the operational impact if this system is unavailable, regardless of its data? Factors considered include: downstream system dependencies, number and seniority of users, regulatory process dependencies, availability of manual workarounds, and estimated time to material impact.

Responsible
System Owner + IT

Question	Guidance
What systems or processes depend on this system?	List all upstream and downstream integrations. If a Tier 1 system depends on this system, functional criticality is at minimum Tier 1.
How quickly does business impact occur if the system fails?	Immediate (minutes) → Tier 1. Hours → Tier 2. Days → Tier 3. Weeks or longer → Tier 4.
Does a viable manual workaround exist?	No workaround → elevates tier. Unsustainable workaround → Tier 2 at minimum. Practical workaround → may support Tier 3.
What is the regulatory impact of unavailability?	Regulatory breach or patient/product safety risk → Tier 1 minimum. SOX reporting impact → Tier 2 minimum.
What is the user population and its criticality?	Company-wide dependency → elevates tier. Single team dependency with workaround → may support Tier 3.

Step 04

Reconciliation — Determine Final Classification

The System Owner records Input A (data-derived) and Input B (functional) on WI-005. The final classification is the higher of the two. This is a non-negotiable rule: a system cannot be classified below either of its two inputs. The System Owner documents the rationale for both inputs on WI-005.

Responsible
System Owner

Input A (Data-Derived)	Input B (Functional)	Final Classification	Example
Tier 4 — None	Tier 1 — Extremely Critical	Tier 1 — Extremely Critical	DNS: no critical data, but immediate operational impact if down
Tier 1 — Extremely Critical	Tier 2 — Critical	Tier 1 — Extremely Critical	Clinical CDMS: critical GxP data, significant functional role
Tier 2 — Critical	Tier 1 — Extremely Critical	Tier 1 — Extremely Critical	ERP at month-end: critical financial data, company-wide

Input A (Data-Derived)	Input B (Functional)	Final Classification	Example
			dependency
Tier 3 — Standard	Tier 4 — None	Tier 3 — Standard	Archival document store: moderate data value, low functional criticality
Tier 4 — None	Tier 3 — Standard	Tier 3 — Standard	Internal wiki: low data value, specific team dependency

Step 05

Regulatory Flag Assignment

The System Owner, with Compliance/QA input, assigns applicable regulatory flags in WI-005. Flags are not tiers — a system may carry multiple flags regardless of its criticality tier. Flags drive additional control obligations (CSV/CSA, ITGC testing, audit trail requirements) as detailed in POL-005 Section 7.

Responsible
System Owner + Compliance/QA

Flag	Trigger Condition	Additional Obligation
GxP-Regulated	System creates, modifies, stores, archives, retrieves, or transmits GxP electronic records.	Full CSV or CSA required (POL-006). Immutable audit trail. Minimum Tier 2 classification.
21 CFR Part 11 / Annex 11	System uses electronic records or e-signatures in place of paper under FDA or EMA jurisdiction.	E-signature controls. Audit trail integrity. System validation to 21 CFR Part 11 standard.
SOX In-Scope	System is within the ITGC boundary for SOX financial reporting controls.	Annual ITGC testing. Access management, change management, and backup controls evidenced. Minimum Tier 2.
HIPAA	System processes US Protected Health Information (PHI).	PHI access controls. Breach notification readiness. Business Associate Agreement with vendors.
GDPR / Privacy	System processes EU or other regulated personal data.	Data inventory entry. DPIA if high risk. Data retention controls per POL-002.

GxP: A GxP-Regulated or SOX In-Scope flag always elevates the minimum classification to Tier 2 — Critical, regardless of Input A and Input B results. If either flag is assigned and both inputs are Tier 3 or Tier 4, the final classification must be raised to Tier 2.

Step 06

Approval

The completed WI-005 is submitted to Information Security for review. Information Security validates both inputs, the reconciliation, and the regulatory flag assignments. Approval authority is tier-dependent:

Responsible
Information Security / CISO

Final Classification	Required Approvers	Target Turnaround
Tier 1 — Extremely Critical	Information Security + CISO	5 business days
Tier 2 — Critical	Information Security	3 business days
Tier 3 — Standard	Information Security	3 business days
Tier 4 — None	Information Security (light review)	2 business days

If Information Security identifies issues with the assessment, the WI-005 is returned to the System Owner with documented feedback. The System Owner must address all feedback and resubmit before approval is granted.

Step 07

Asset Register Entry

Upon approval, Information Security or the Data Custodian creates or updates the system record in the Corporate Asset Register. All mandatory fields must be completed before the system is cleared for production deployment.

Responsible
IT / Information Security

Asset Register Field	Source
System Name and Description	System Owner (WI-005)
System ID	IT — assigned on registration
Criticality Tier (Final)	WI-005 reconciliation output
Input A — Data-Derived Tier	WI-005 Section A
Input B — Functional Tier	WI-005 Section B
Regulatory Flags	WI-005 Section C
System Owner	WI-005
IT Custodian	IT
Classification Date	Date of CISO/InfoSec approval
Next Review Date	Classification date + 12 months
RPO Target	Per POL-005 Section 4, by tier
RTO Target	Per POL-005 Section 4, by tier
Deployment Model	System Owner (WI-005)
DR Strategy Confirmed	Business Continuity sign-off (Tier 1 and 2)

Step 08

Controls Implementation Verification

IT confirms that the technical controls mandated for the assigned criticality tier (per POL-005 Section 6) are in place or have a documented

Responsible
IT / Information Security

implementation plan with a target date. For Tier 1 systems, controls must be verified as in place before production go-live. For Tier 2 systems, a gap remediation plan with a maximum 30-day completion window is acceptable at go-live. Information Security signs off controls verification.

Control Domain	Tier 1 Verification Required	Tier 2 Verification Required
Architecture / HA	HA configuration confirmed. Failover tested.	HA or DR strategy documented and approved.
Backup	Backup running. Restore tested. RPO confirmed.	Backup configured. Restore test scheduled within 30 days.
Monitoring	24/7 monitoring active. Alerting tested. 15-min SLA set.	Business hours monitoring active. On-call process documented.
Patching	Emergency patch process documented.	Patch schedule aligned to criticality requirements.
Access Review	Quarterly access review scheduled.	Semi-annual access review scheduled.
DR Test	Full DR test scheduled within 90 days of go-live.	DR test scheduled within 12 months of go-live.
GxP CSV/CSA (if flagged)	Validation documentation complete. QA signed off.	Validation plan approved. Execution scheduled.

7. Annual Review Process

All classified systems must be reviewed and the classification reconfirmed at least annually. The review cycle is managed by Information Security.

Step	Action	Responsible
7.1	60 days before a system's review date, Information Security sends a review notification to the System Owner, including the current classification, regulatory flags, and Asset Register entry.	Information Security
7.2	The System Owner reviews the system against the trigger events in Section 4. Have there been changes to data types, functionality, integrations, or regulatory scope since the last classification?	System Owner
7.3	If no material changes: System Owner confirms the classification in writing. The next review date is updated to 12 months from the confirmation date.	System Owner
7.4	If material changes have occurred: the full classification process (Steps 1–8) is repeated for the affected inputs. The previous classification remains in force until the new classification is approved.	System Owner + IT
7.5	If a system has been decommissioned or is no longer active, the System Owner notifies Information Security. The system is marked as decommissioned in the Asset Register. Data disposal must comply with POL-002.	System Owner / IT
7.6	Systems overdue for review by more than 30 days are flagged as non-compliant in the Asset Register and escalated to the System Owner's line manager and the ISSG.	Information Security

8. Reclassification

8.1 Upward Reclassification

Upward reclassification (to a higher criticality tier) may be initiated at any time by the System Owner or Information Security. It follows the same approval workflow as Steps 4–8 above. Controls for the new tier must be implemented or gap-remediated within the timelines defined in Section 6, Step 8. The previous classification remains in force until the new one is approved.

8.2 Downward Reclassification

Downward reclassification requires a higher standard of evidence and approval:

From → To	Additional Requirement
Tier 1 → Tier 2 or below	System Owner submits written justification. Information Security validates both inputs have genuinely changed. CISO approval required. Business Continuity confirms revised DR obligations are met.
Tier 2 → Tier 3 or below	System Owner submits written justification. Information Security validates both inputs. Compliance/QA confirms no regulatory flag uplift applies.
Any → below regulatory minimum (GxP / SOX)	Not permissible while regulatory flag is active. Flag must be removed first, with Compliance/QA and CISO approval.

All reclassification decisions — upward or downward — must be recorded in the Asset Register with: date, previous classification, new classification, rationale, and approver names.

9. Dispute Resolution

Where there is disagreement between the System Owner, IT, Compliance/QA, or Information Security on the appropriate classification, the following escalation path applies:

1. The party raising the dispute submits a written statement to Information Security, identifying the disputed input (A or B) or regulatory flag and the competing assessments.
2. Information Security convenes a review meeting with the relevant parties within 5 business days. Business Continuity and Compliance/QA are included if RPO/RTO or regulatory flags are in dispute.
3. Information Security issues a written determination within 3 business days of the review meeting. This determination is binding pending escalation.
4. If the System Owner or another party disputes the determination, the matter is escalated to the CISO for final resolution.
5. The CISO's determination is final. It is recorded in the Asset Register and the exception log maintained by Information Security.

IMPORTANT: While a classification dispute is active, the system must operate under the higher of the two competing classifications.

10. Third-Party and Cloud-Hosted Systems

Third-party and cloud-hosted systems follow the same classification process as internally hosted systems, with the following additional steps embedded within the workflow:

Step	Additional Requirement for Third-Party Systems
Step 3 (Functional Assessment)	The System Owner must obtain and review the vendor's BCR/DR documentation before completing Input B. Vendor-stated RPO/RTO must be compared against the tier requirement.
Step 5 (Regulatory Flags)	GxP-Regulated flag: a Technical Agreement must be in place with the vendor specifying CSV/CSA and audit trail obligations. SOX In-Scope flag: vendor must demonstrate ITGC controls (SOC 2 Type II or equivalent).
Step 6 (Approval)	For Tier 1 third-party systems, the CISO must confirm that contractual right-to-audit is in place before approval is granted.
Step 7 (Asset Register)	Asset Register entry must include: vendor name, vendor contact, contract expiry date, SLA reference, and date of last vendor review.
Step 8 (Controls Verification)	For Tier 1 and Tier 2 third-party systems, Business Continuity must confirm that the vendor's DR commitments meet the RPO/RTO requirements of the tier.

11. Records and Evidence

Record	Location	Retention Period	Responsible
Completed WI-005	Corporate Asset Register / document management system	Life of system + 5 years	Information Security
Classification approval (InfoSec / CISO)	Corporate Asset Register	Life of system + 5 years	Information Security
Annual review confirmations	Corporate Asset Register	5 years	Information Security
Controls verification sign-off	Corporate Asset Register / IT records	Life of system + 5 years	IT / Information Security
Reclassification records	Corporate Asset Register	Life of system + 5 years	Information Security
Dispute adjudications	Information Security records	5 years	Information Security
Decommission records	Corporate Asset Register	10 years	IT / Information Security

12. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Overarching framework; defines dual-input classification schema
POL-005	System Classification Policy	Parent policy — this SOP operationalises it
WI-005	System Classification Questionnaire	Task-level execution tool used in Steps 2–5
SOP-001	Data Classification Process	Data classification outputs are a required input to Step 2 (Input A)
POL-001	Data Classification Policy	Defines data sensitivity tiers referenced in Input A assessment
POL-006	Computer System Validation and Qualification Policy	Track A (GxP flag) → Full CSV/CSA. Track B (SOX, non-GxP) → ITGC. Track C (Tier 1/2, no flag) → Structured Qualification. Track D (Tier 3/4, no flag) → Lightweight. Governs CSV/CSA requirements triggered by GxP regulatory flag
POL-007	Change Management Policy	Governs change type eligibility and approval authority by criticality tier and regulatory flags. GxP-flagged: validation impact assessment mandatory for all changes.
POL-008	Access Control Policy	Access review cadence is a direct output of system classification — Tier 1/GxP: quarterly; Tier 2: semi-annual/quarterly; Tier 3/4: annual. Controls verification (Step 6) confirms POL-008 access controls are implemented per tier.
POL-009	Privileged Access Management Policy	JIT privileged access and session recording requirements are tier-scaled controls verified at Step 6; PAM platform requirement applies to Tier 1 and Tier 2 systems.
POL-010	Information Security Risk Policy	System-level risk assessment is a required pre-go-live input (Step 5) for Tier 1/2 systems; the classification output (criticality tier, regulatory flags) feeds directly into risk scoring context; system risks identified during classification flow into the IS Risk Register under POL-010
POL-011	Business Continuity Policy	DR strategy and RPO/RTO requirements by tier
POL-013	Third Party and Vendor Risk Policy	Additional requirements for third-party classified systems

13. Definitions

Term	Definition
Asset Register	The central corporate inventory of all data assets and systems, including classification, ownership, and regulatory flag records.
CSA	Computer Software Assurance — the FDA's risk-based approach to assuring software used in regulated activities.
CSV	Computer System Validation — documented demonstration that a system does what it purports to do consistently and reproducibly.
Data-Derived Criticality	Input A: the criticality assessment based on the operational impact of the data the system holds becoming unavailable or corrupted.
Functional Criticality	Input B: the criticality assessment based on the operational impact of the system itself being unavailable, independent of its data.
GxP-Regulated	A system that creates, modifies, stores, archives, retrieves, or transmits electronic records required under applicable Good Practice regulations.
HA	High Availability — architecture designed to minimise downtime through redundancy and automated failover.
ITGC	IT General Controls — IT controls that support the effectiveness of application controls for SOX financial reporting compliance.
RPO	Recovery Point Objective — the maximum acceptable age of data at the point of recovery following a failure.
RTO	Recovery Time Objective — the maximum acceptable duration of a system outage before recovery must be complete.
System Owner	The individual accountable for the lifecycle, classification, and controls applied to a specific information system.

— End of Document —

SOP-005 v1.0 DRAFT | [Company Name] | CONFIDENTIAL